AUTHORIZATION

SECURE WEB DEVELOPMENT

Outline

- Definition
- Principle of Least Privilege
- Centralized Authorization Routines
- Controlling Access to Protected Resources
- Some Generic Types of Access Controls
- Access Control Models
- Examples of Access Controls in Software:

Authorization is the process of giving someone permission to do or have something.

Also known as Access Control — is mediating access to resources based on identity and is generally policy-driven.

Principle of Least Privilege

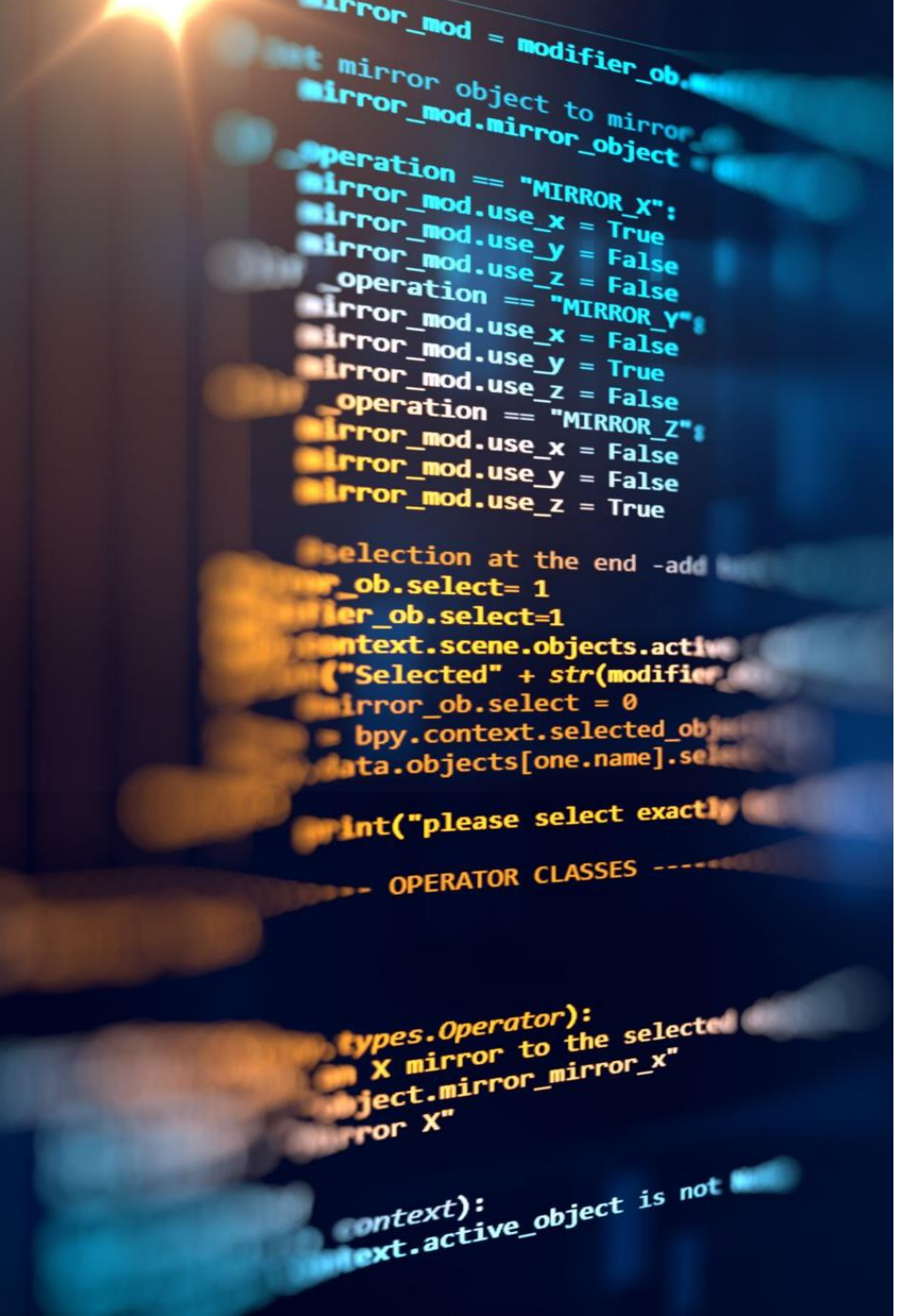
Principle of Least Privilege

Encourages system designers and implementers to allow running code only the permissions needed to complete the required tasks and no more.

Principle of Least Privilege

Spans the configuration of the web and application servers through the business capabilities of business logic components.

Centralized Authorization Routines



Centralized Authorization Routines

A common mistake is to perform an authorization check by cutting and pasting an authorization code snippet into every page containing sensitive information.

Centralized Authorization Routines

Worse yet would be re-writing this code for every page.

Centralized Authorization Routines

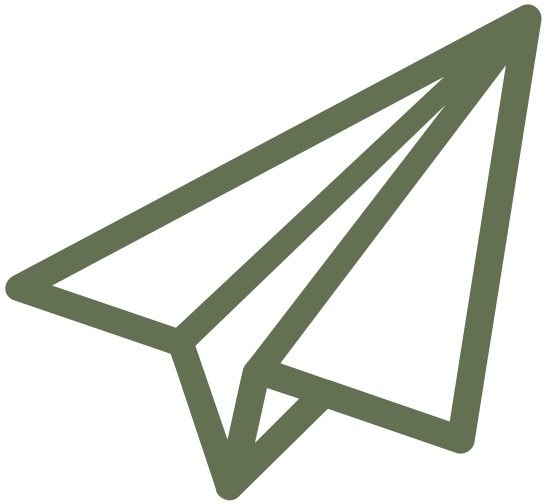
Well written applications centralize access control routines, so if any bugs are found, they can be fixed once, and the results apply throughout the application immediately.

Controlling Access to Protected Resources

Controlling Access to Protected Resources

Some applications check to see if a user can undertake a particular action, but then do not check if access to all resources required to complete the requested action is allowed.

Controlling Access to Protected Resources



For example, forum software may check to see if a user can reply to a previous message, but then fails to check that the requested message is not within a protected or hidden forum or thread.

Controlling Access to Protected Resources

Another example would be an Internet Banking application that checks to see if a user can transfer money but does not validate that the “from account” is one of the user’s accounts.

Generic Types of Access Controls

Network Access

- Ability to connect to a system or service

Host Access

- Access to operating system functionality

Physical Access

- Locations that are housing information assets
- Physical access to the assets themselves

Restricted Functions

- Operations evaluated as having an elevated risk
- Examples: Financial transactions, changes to system configuration, or security administration

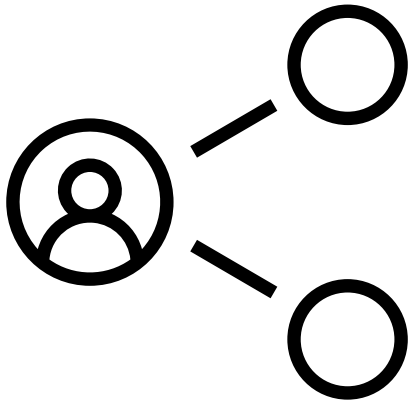
Resource access may refer not only to files and database functionality, but also to:

- Applications or APIs
- Specific Application Screens/Functions
- Specific Data Fields
- Memory
- Private/Protected Variables
- Storage Media
- Transmission Media

In short, <u>any object used in processing, storage or transmission of information</u>.

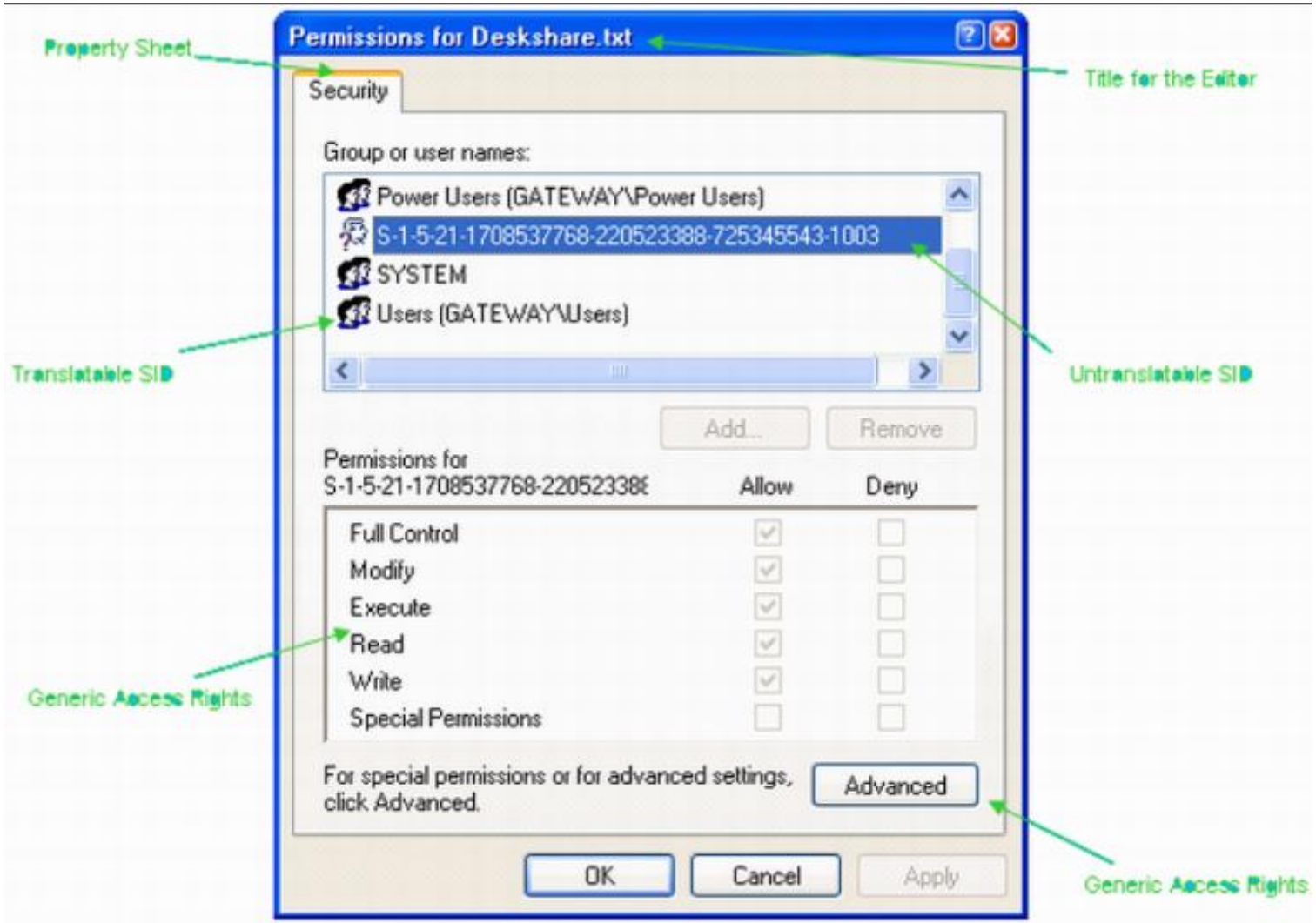
Access Control Models

Access Control Models

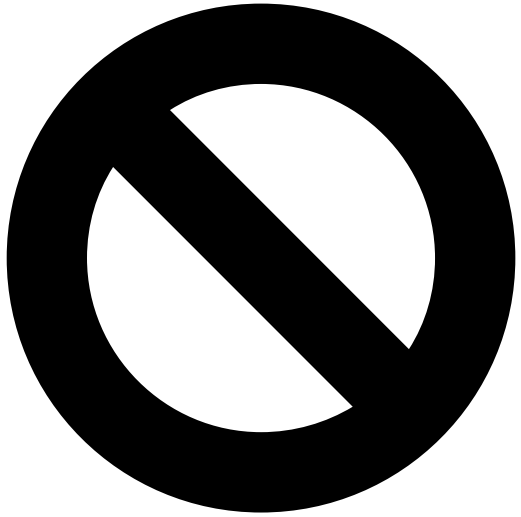


Discretionary access controls

- Based on the identity and need-to-know of subjects and/or the groups to which they belong.
- They are discretionary in the sense that a subject with certain access permissions is capable of passing on that access, directly or indirectly, to other subjects.


Property Sheet
Permissions for Deskshare.txt
Title for the Editor
Security
Group or user names:
Power Users (GATEWAY\Power Users)
S-1-5-21-1708537768-220523388-725345543-1003
SYSTEM
Users (GATEWAY\Users)
Translatable SID
Untranslatable SID
Add...
Remove
Permissions for
S-1-5-21-1708537768-22052338
Allow
Deny
Full Control
Modify
Execute
Read
Write
Special Permissions
Generic Access Rights
For special permissions or for advanced settings, click Advanced.
Advanced
OK
Cancel
Apply
Generic Access Rights

Access Control Models



Mandatory access controls

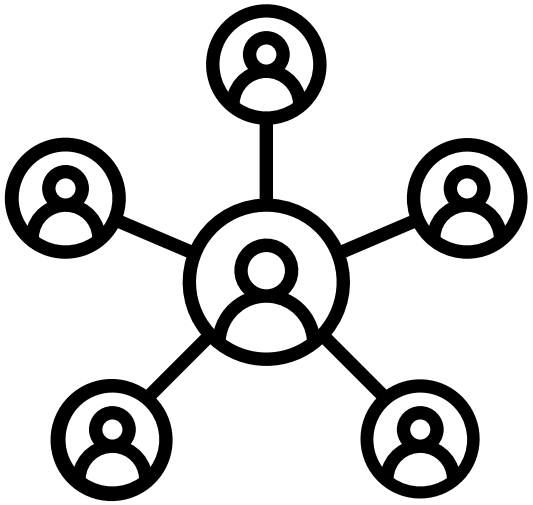
- Based on the sensitivity of the information contained in the objects / resources and a formal authorization.
- They are mandatory in the sense that they restrain subjects from setting security attributes on an object and from passing on their access.

Defined integrity levels

System	High	Medium	Low	Untrusted
400	300	200	100	0
Local System	Local Service Network Service Elevated (full) user tokens	Standard user tokens Authenticated Users	World (Everyone)	Anonymous All other tokens

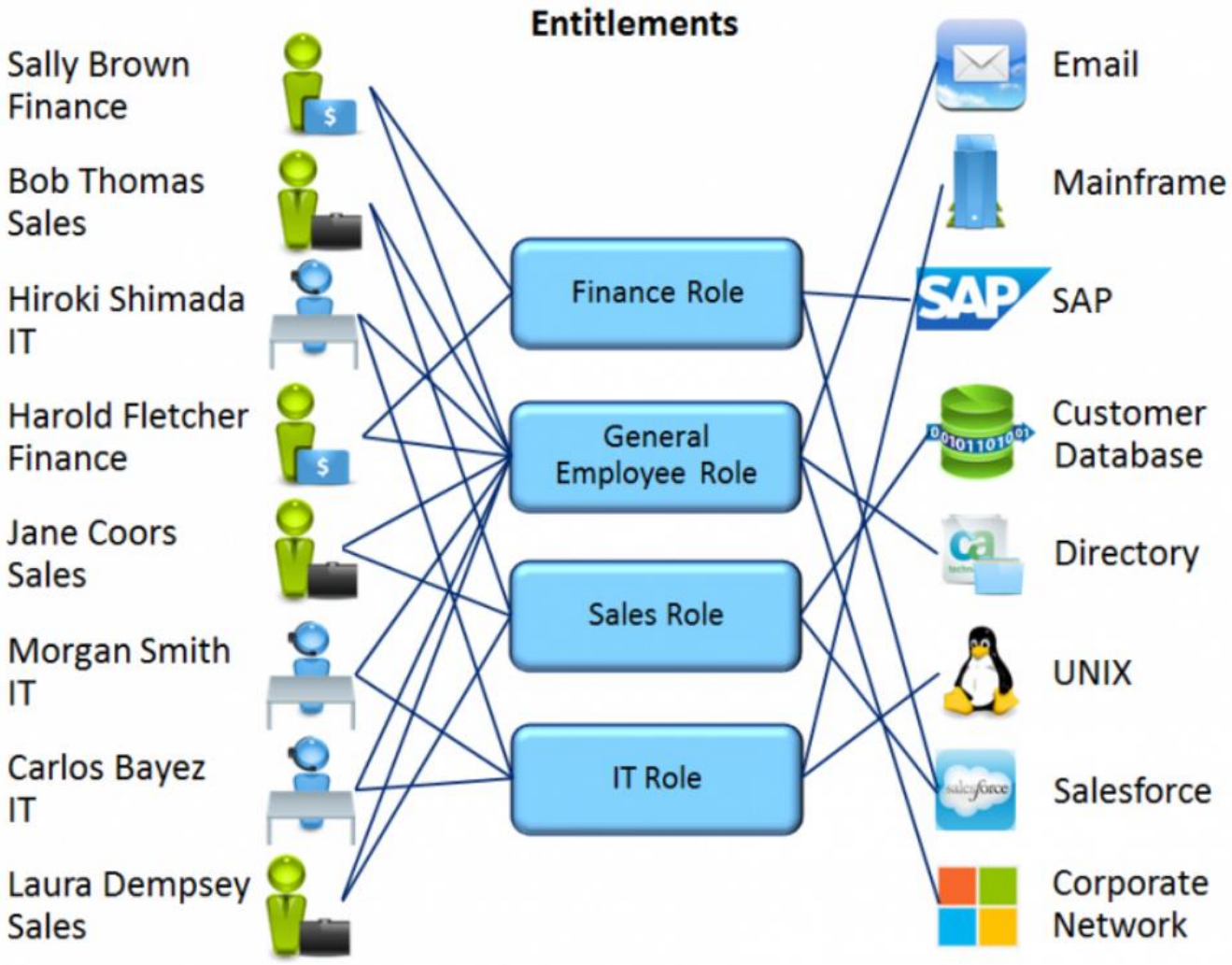
Shell runs here

Access Control Models



Role-based access controls (RBAC)

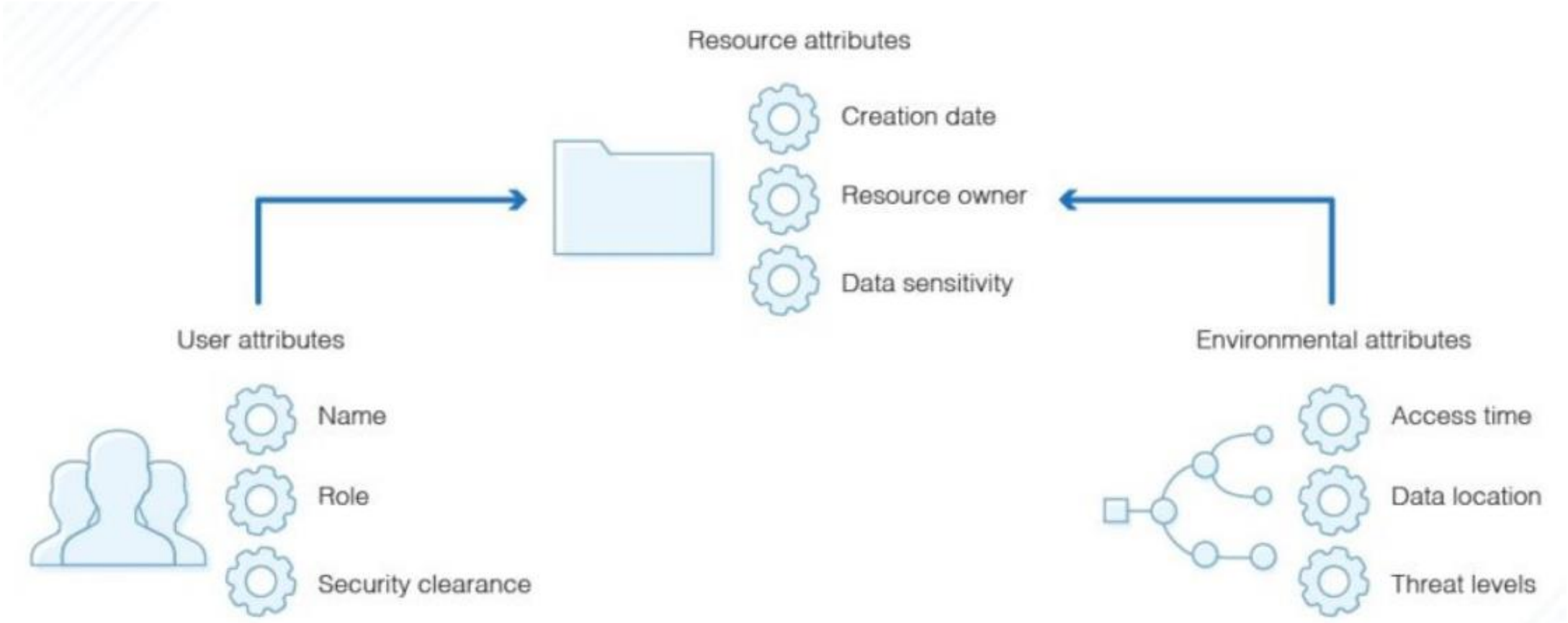
- §Based on the roles played by users and groups in organizational functions.
- §Roles, alternatively referred to as security groups, include collections of subjects that all share common needs for access.
- §Authorization for access is then provided to the role or group and inherited by members.


Entitlements
Sally Brown
Finance
Bob Thomas
Sales
Hiroki Shimada
IT
Harold Fletcher
Finance
Jane Coors
Sales
Morgan Smith
IT
Carlos Bayez
IT
Laura Dempsey
Sales
Finance Role
General Employee Role
Sales Role
IT Role
Email
Mainframe
SAP
Customer Database
Directory
UNIX
Salesforce
Corporate Network

Access Control Models

Attribute-based access control (ABAC)

- A newer paradigm based on properties of an information exchange that may include identified attributes of the requesting entity, the resource requested, or the context of the exchange or the requested action.


Resource attributes
Creation date
Resource owner
Data sensitivity
User attributes
Name
Role
Security clearance
Environmental attributes
Access time
Data location
Threat levels

Examples of Access Controls in Software

Account management

Mapping of user rights to business and process requirements

Mechanisms that enforce policies over information flow

Limits on the number of concurrent sessions

Session lock after a period of inactivity

Session termination after a period of inactivity, total time of use or time of day

Limitations on the number of records returned from a query (data mining)

Features enforcing policies over segregation of duties

Segregation and management of privileged user accounts

Implementation of the principle of least privilege for granting access

Requiring VPN (virtual private network) for access

Dynamic reconfiguration of user interfaces based on authorization

Restriction of access after a certain time of day

AUTHORIZATION

SECURE WEB DEVELOPMENT